

# *Networks and Systems Security II*

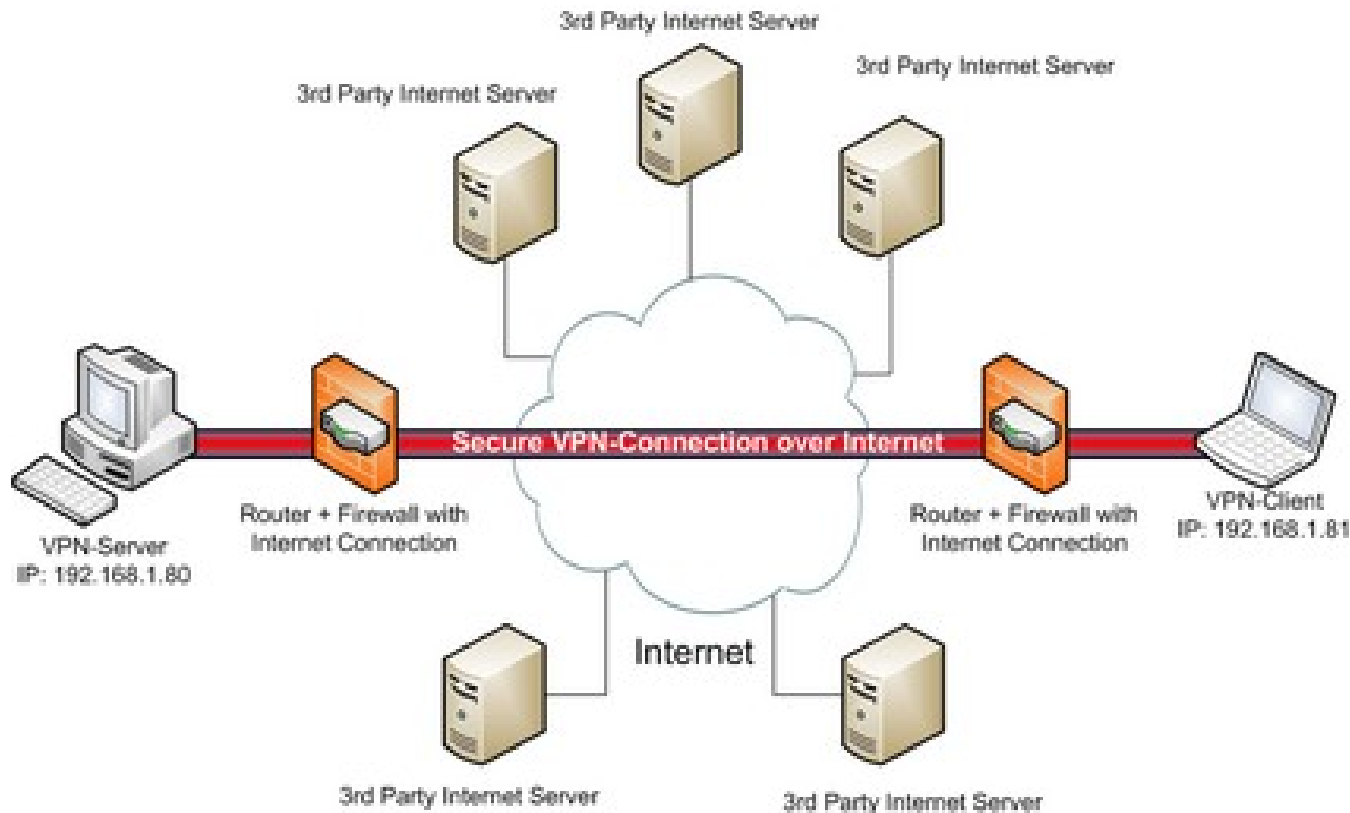
**CSE 554**

Instructor: Sambuddho

(Semester: Winter 2025)

# Virtual Private Networks

- Aka tunnelling
- Communication between peers via the Internet while without revealing to the world the actual IP address.



# Tunneling Schemes

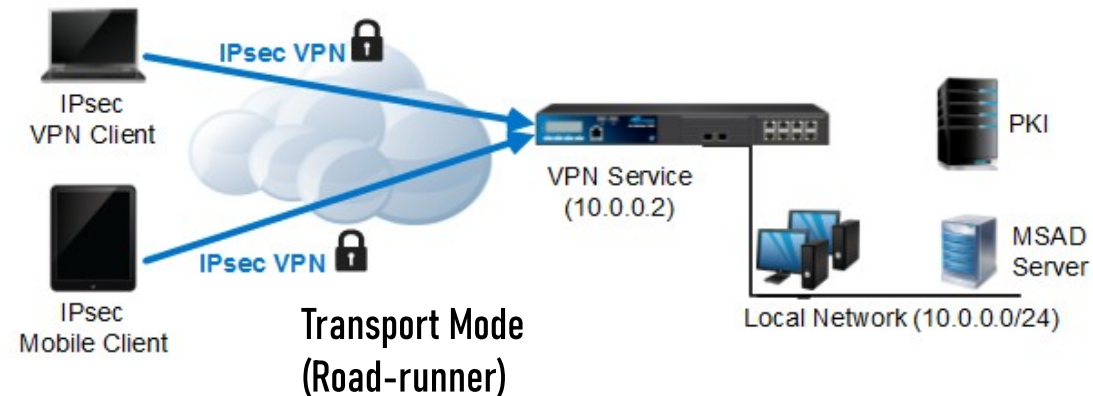
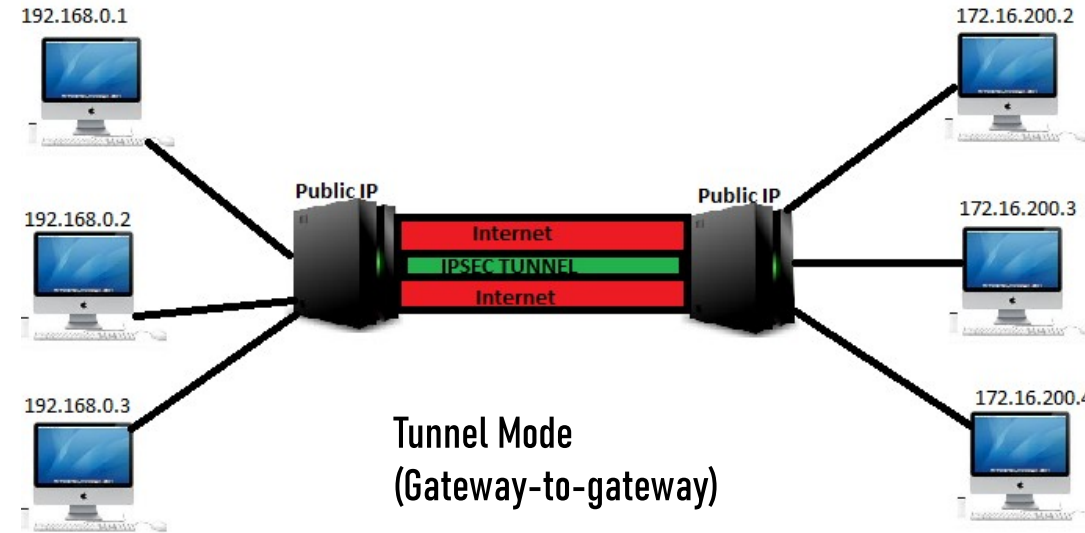
Point-to-point Tunnelling Protocol (PPTP):

- Invented by MS, used for large scale tunnelling over wide area networks (Internet).
- Application layer proxying uses port 1723.
- Tunnelling over GRE tunnels.
- Security -
  - MS-CHAP (Challenge handshake auth. Protocol) + RC4 (encryption)
  - Broken 2012!
- SSH Tunnelling
  - Application layer tunnelling.
  - Client connects to a remote SSH server as a proxy which
  - forwards all traffic to the outside world!
  - Can be also used as socks proxy.

# IPSec (IP Security)

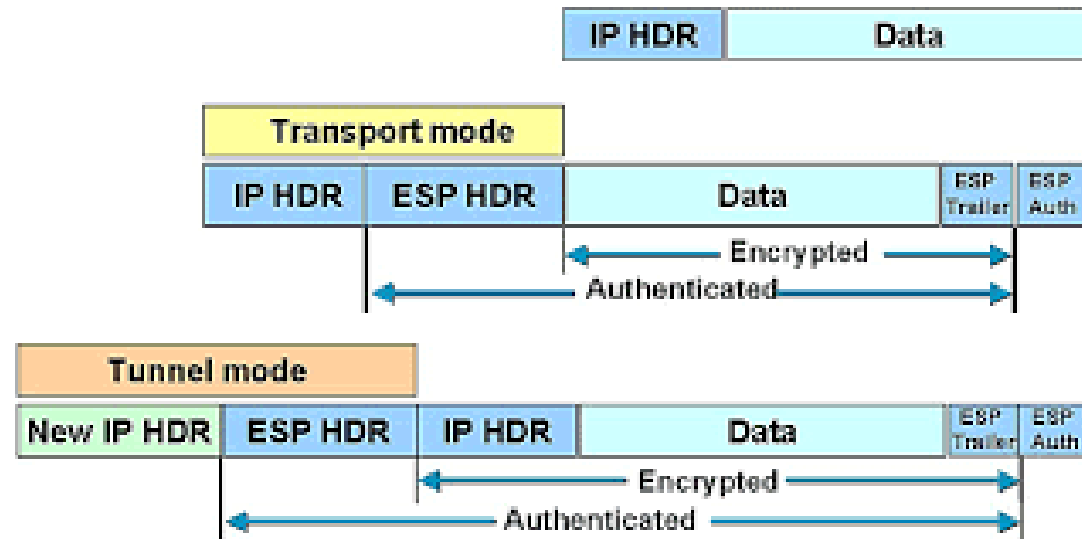
- L3 Tunnelling protocol.
- Two major modes of operation:
  - Authentication Header (AH):
    - Used for authentication+integrity protection.
    - Inserts a AH header between IP and TCP header.
    - Supports both transport mode (road-warrior mode) and tunnel mode (gateway-to-gateway mode).
  - Encapsulated Security Payload (ESP):
    - Authentication+integrity protection+confidentiality.
    - IP-in-IP. Inner IP packet encrypted.
    - Outer IP addresses:
      - Src: Source VPN gateway.
      - Dst: Dest. VPN gateway
- Supports both transport mode (road-warrior mode) and tunnel mode (gateway-to-gateway mode).

# IPSec (IP Security)

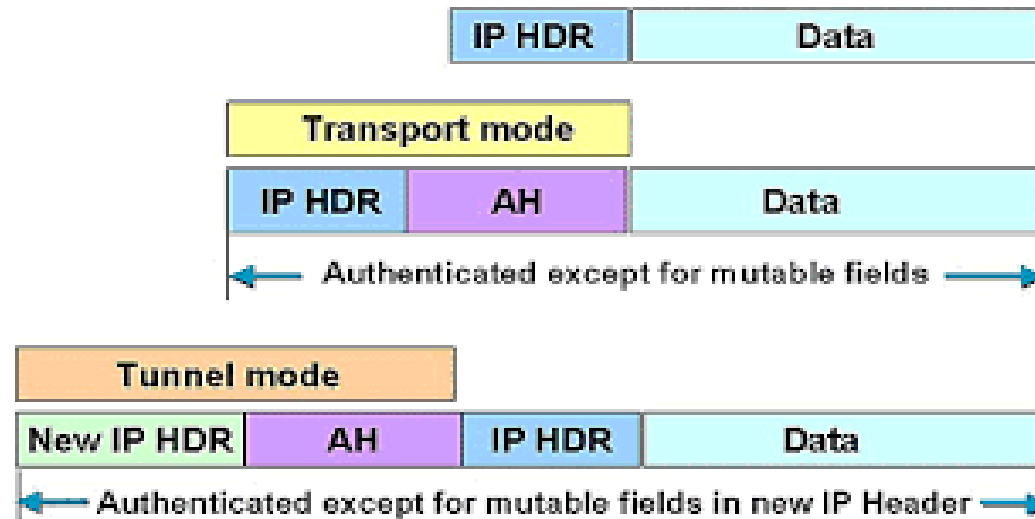


# IPSec Tunnel and Transport Headers

ESP in Tunnel and Transport Mode



AH in Tunnel and Transport Mode



# Issues When Using IPSec

- NAT: IPSec tunnels cannot be used with NAT boxes because NAT boxes would try to change the actual IP address which it cannot in the absence of the encryption key.
- Even transport mode doesn't work - cryptographic checksum cannot be recomputed by the NAT device.
- Firewalls: Firewalls work by inspecting the source and destination IP addresses and port numbers. In case of IPSec prevents inspection of original IP address and port numbers.
- Infact VPNs and IPSec have been used extensively for evading firewalling.

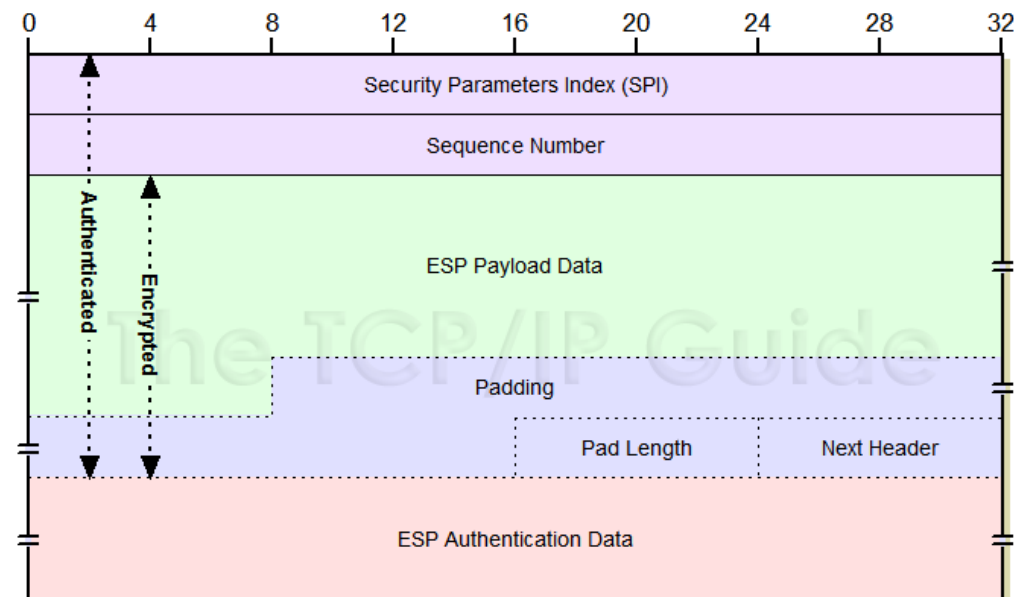
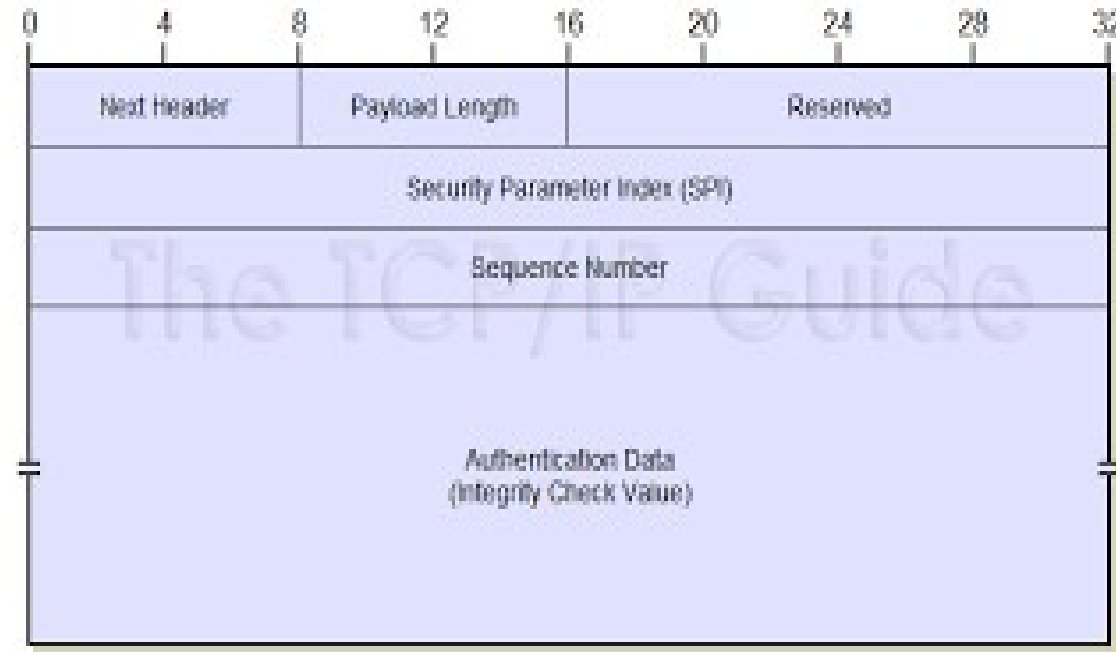


# Header Fields (IPv4)

|                     |     |                 |                 |                 |
|---------------------|-----|-----------------|-----------------|-----------------|
| Ver                 | IHL | Type of Service | Total Length    |                 |
| Identification      |     |                 | Flags           | Fragment Offset |
| Time to Live        |     | Protocol        | Header Checksum |                 |
| Source Address      |     |                 |                 |                 |
| Destination Address |     |                 |                 |                 |
| Options + Padding   |     |                 |                 |                 |



# Header Fields



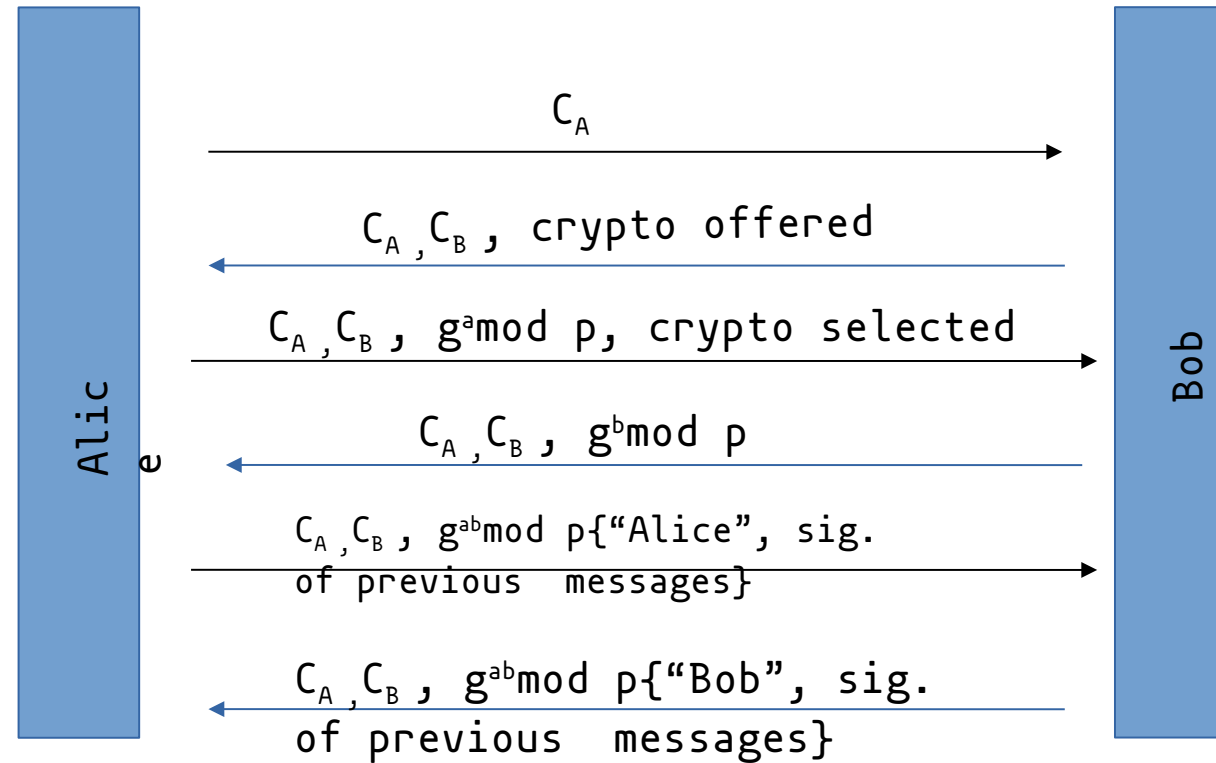
# Key Exchange for IPSec

- Internet Key Exchange (IKE): Part of Internet Security Association and Key Management Protocol (ISAKMP). IKE is part of the ISAKMP.
- Used for key negotiation between the communication peers.
- Main mode and aggressive mode.
- Two phase process - Phase I and Phase II

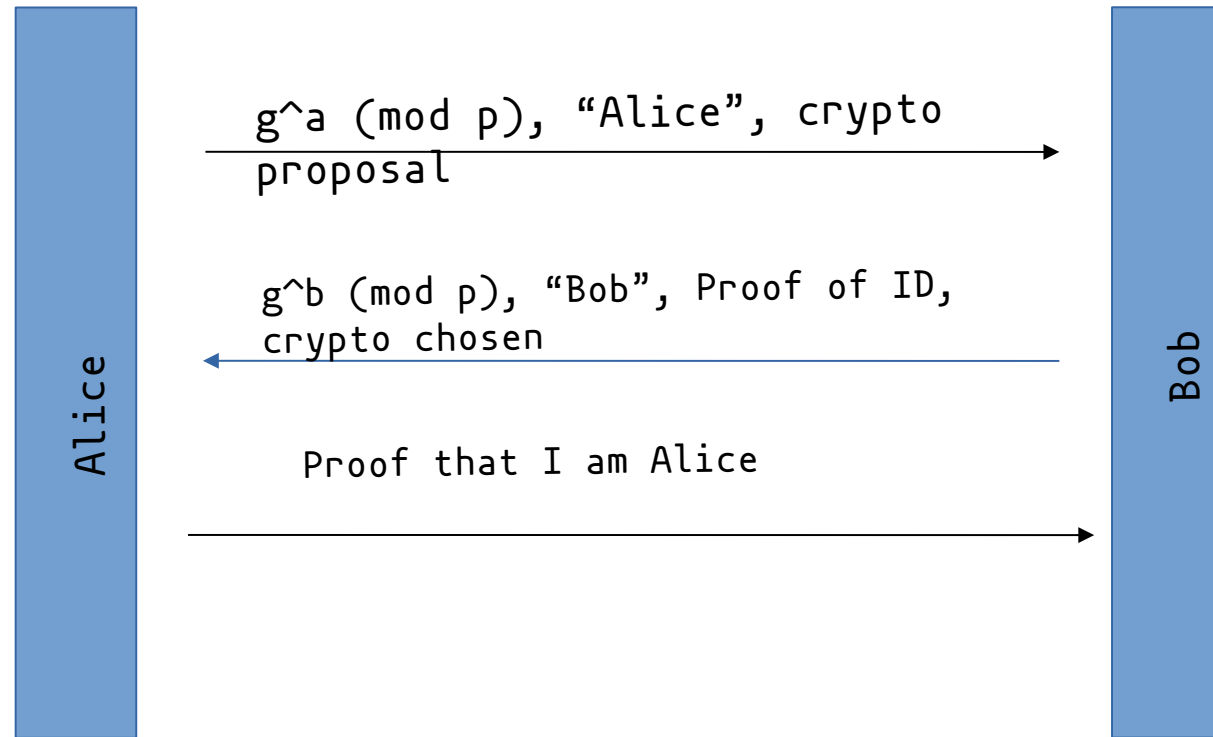
Main types of keys supported -

- Original public private cryptographic keys: Parties encrypt the messages with the others public keys.
  - Revised version - Public key used to encrypt a randomly chosen secret key and sent to the peer which would be used for future communications.
  - Pre-shared key
  - Public key signatures - using the public key only for signatures.
  - Total 8 variants = 4 types of keys x 2 Phases
- 
- Phase II : Negotiate security associations.
  - Why two phases ?

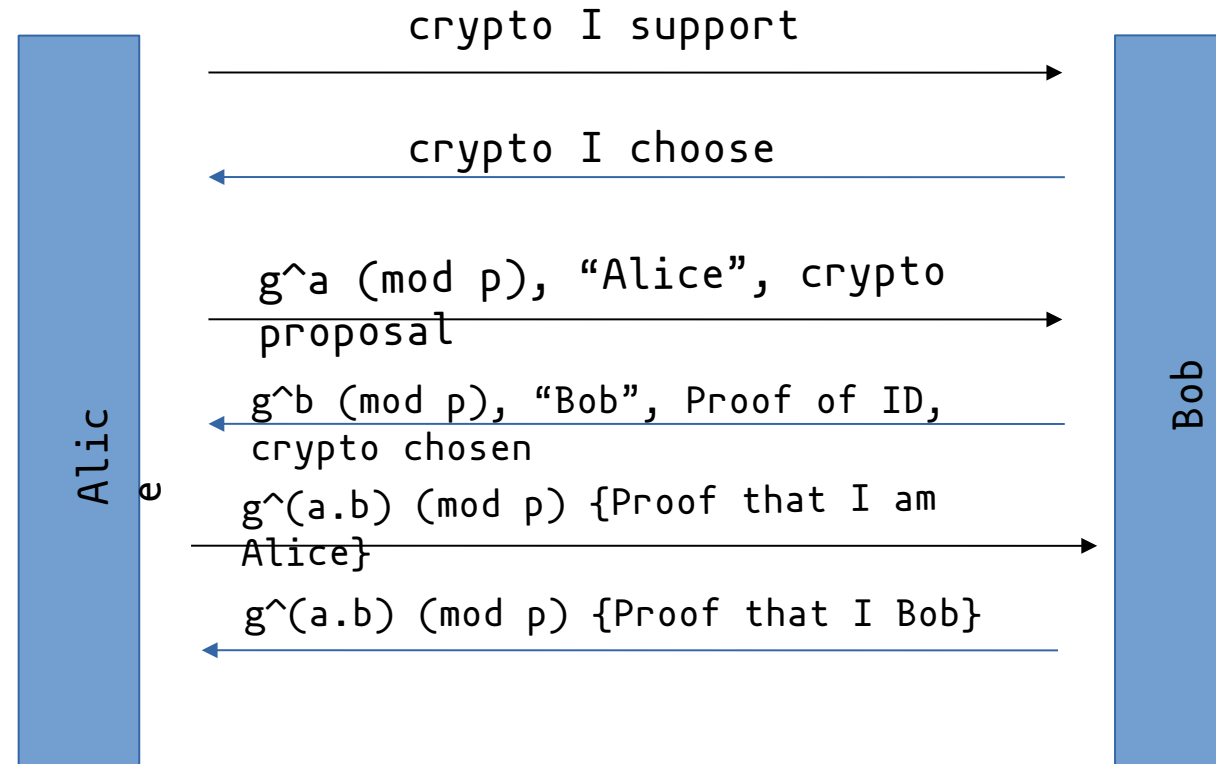
# Photuris - Early Proposal for IKE



# Key Exchange for IPSec - IKE Phase I (Aggressive Mode)



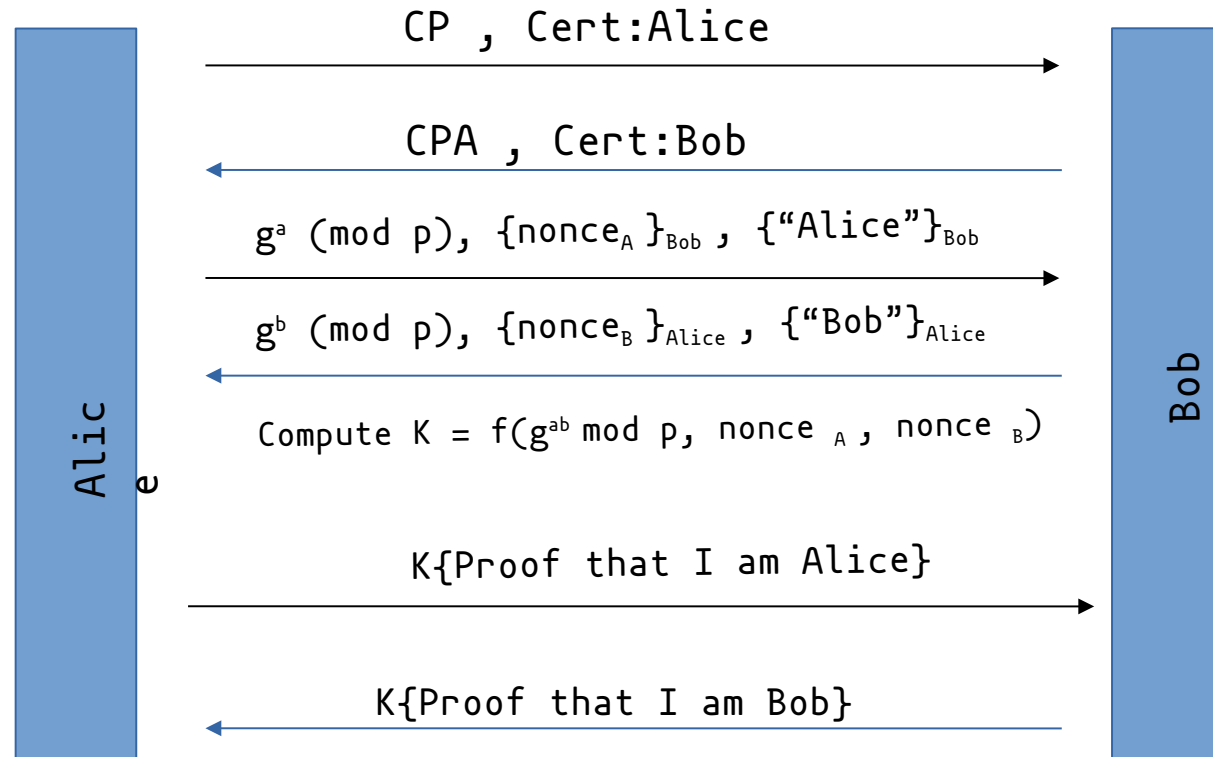
# Key Exchange for IPSec - IKE Phase I (Main Mode)



# Key Types and Key Negotiation

- Types of keys supported: PSK, Public keys (for data enc./dec.), public key for signatures, variant of public key (use public key to encrypt a chosen secret). X 2 (for main mode and aggressive mode) = 8 variants of IKE phase 1
- IKE used by parties to negotiate keys for encryption, integrity protection, auth. and DH parameters.
- Unlike SSL/TLS, IKE presents the same key for both directions.
- Enc. Algos. (3DES, IDEA, AES\_128), HASH (MD5, SHA), Auth (RSA sig., PSK), DH params (mod exponent - g and p)

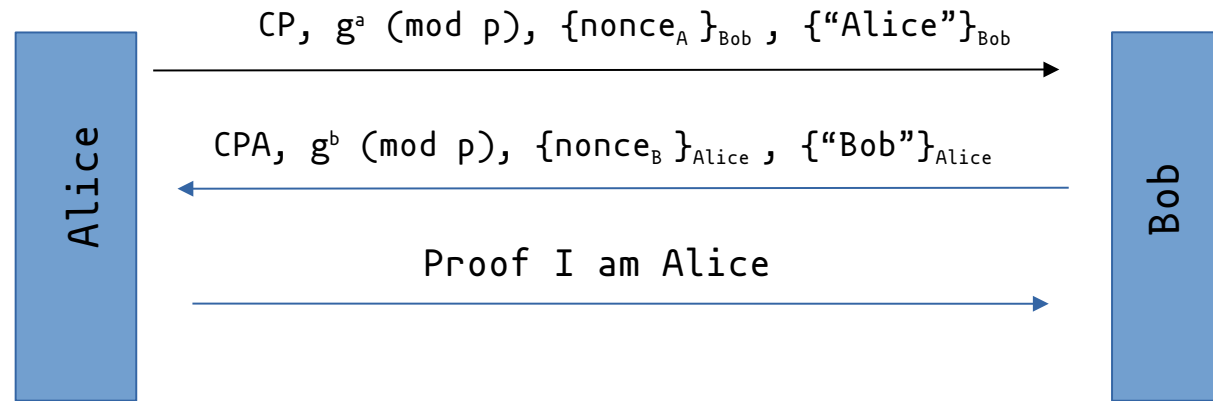
# IKE Phase 1 Protocols - Pub. Key Enc. Original (Main Mode)



*Problem ?*

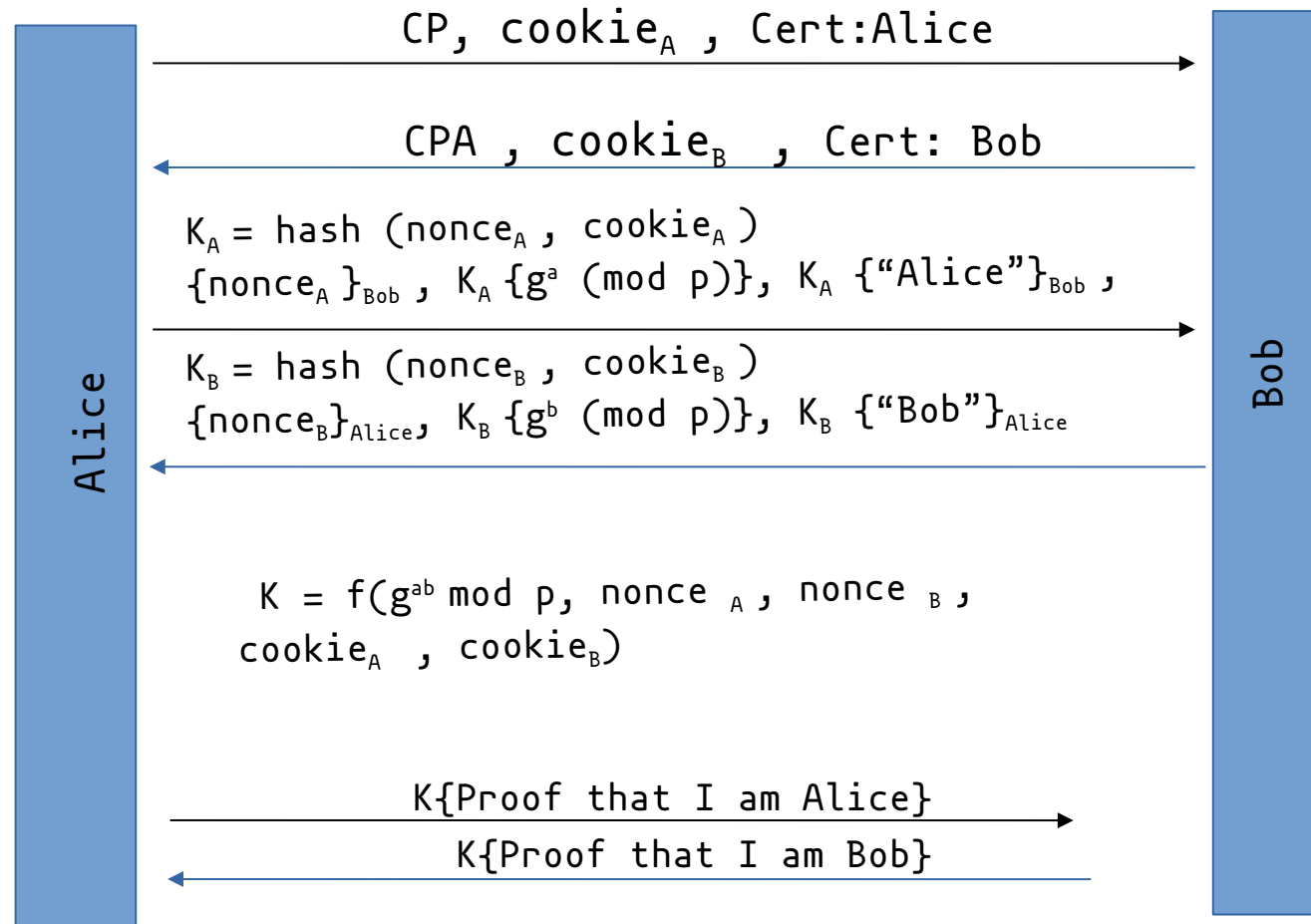
1. Two pub key operations in one single message.
2. Public key sharing...

# IKE Phase 1 Protocols - Pub. Key Enc. Original (Aggressive Mode)

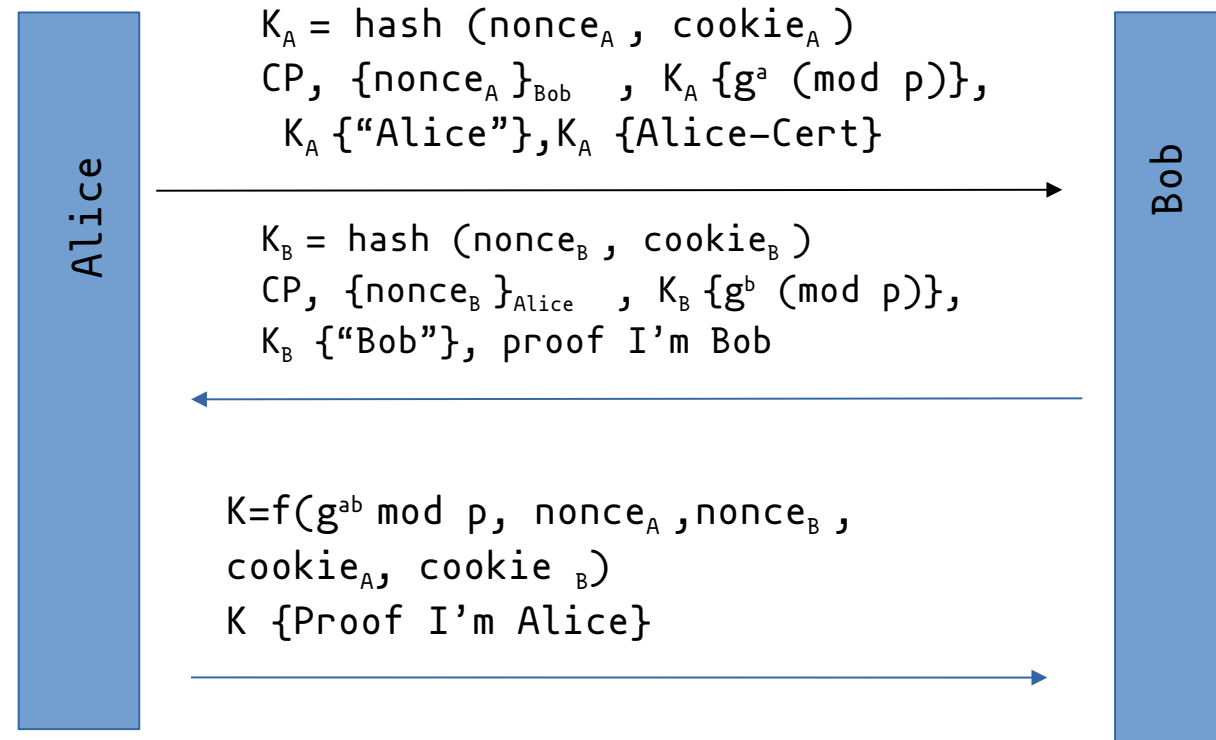




# IKE Phase 1 Protocols - Pub. Key Enc. Revised (Main Mode)



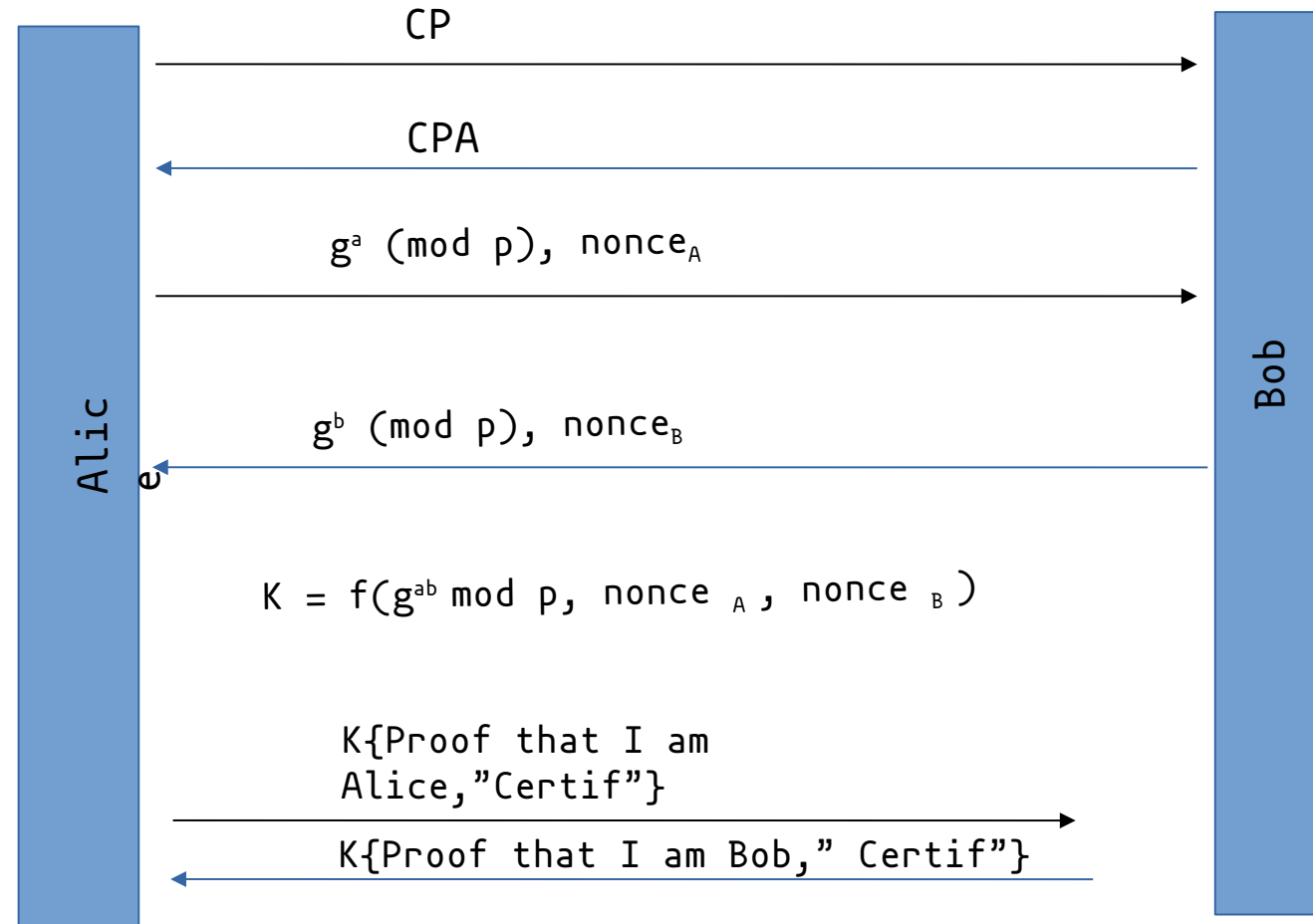
# IKE Phase 1 Protocols - Pub. Key Enc. Revised (Aggressive Mode)



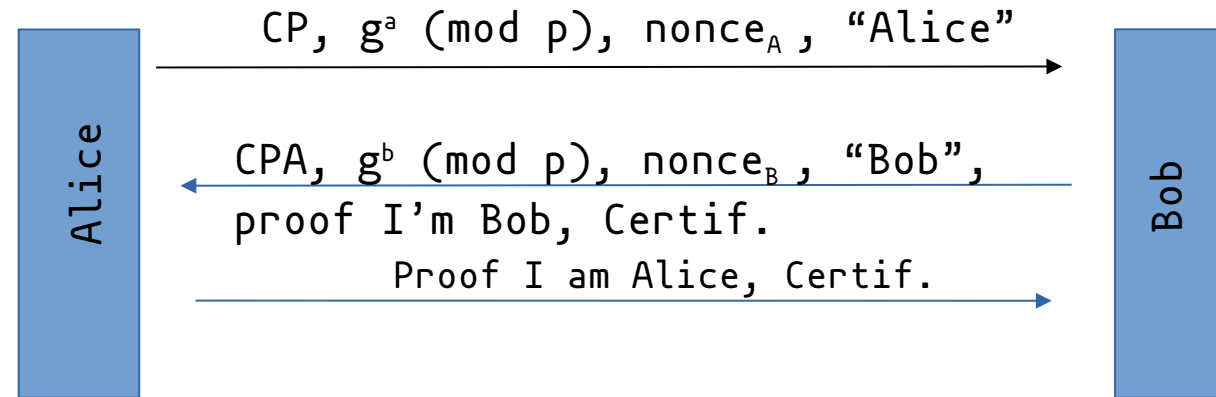
**Problem ?**

1. Public key sharing...

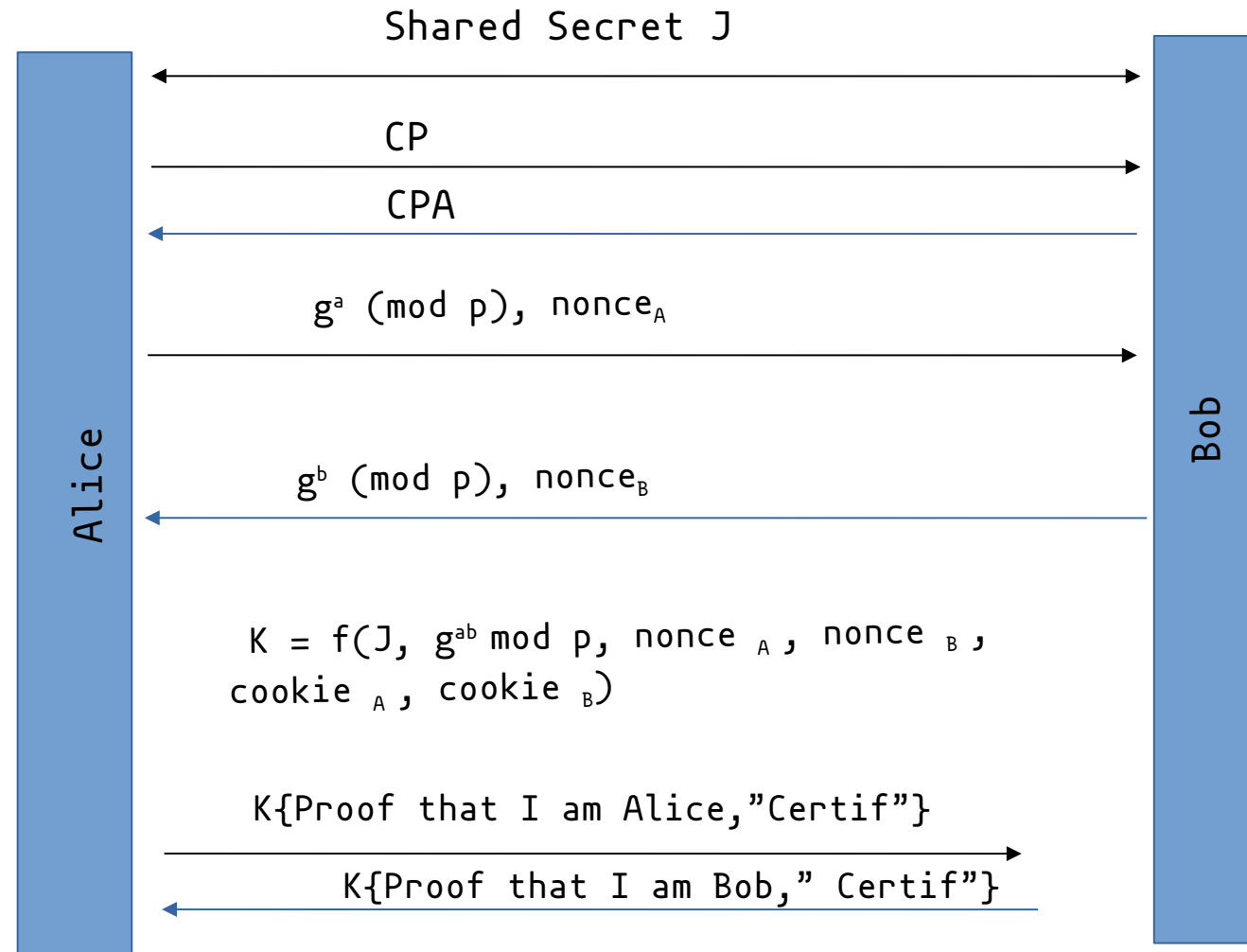
# IKE Phase 1 Protocols - Pub. Key Sig. (Main Mode)



# IKE Phase 1 Protocols - Pub. Key Sig. (Aggressive Mode)



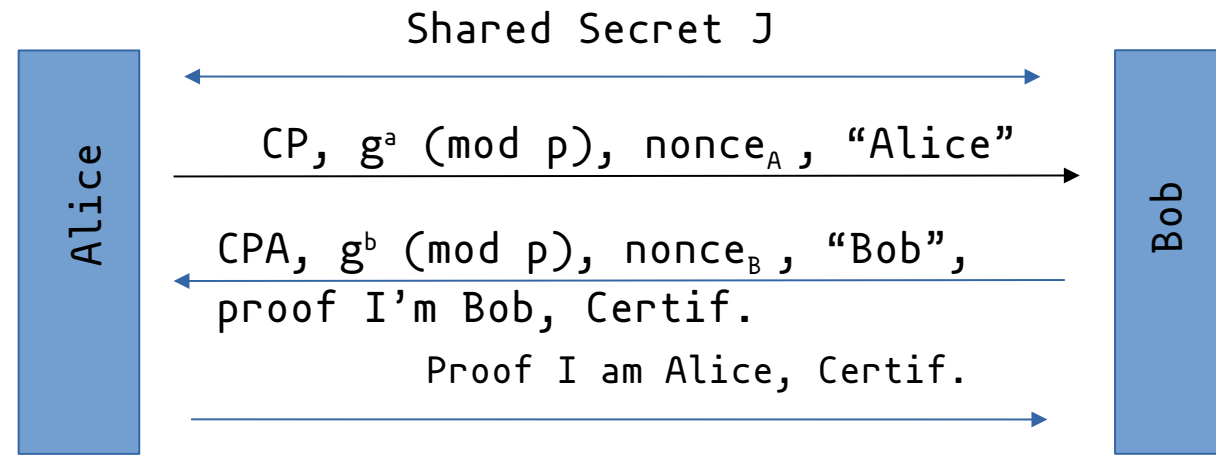
# IKE Phase 1 Protocols - PSK. (Main Mode)



**Problem ?**

1. Certificate is redundant

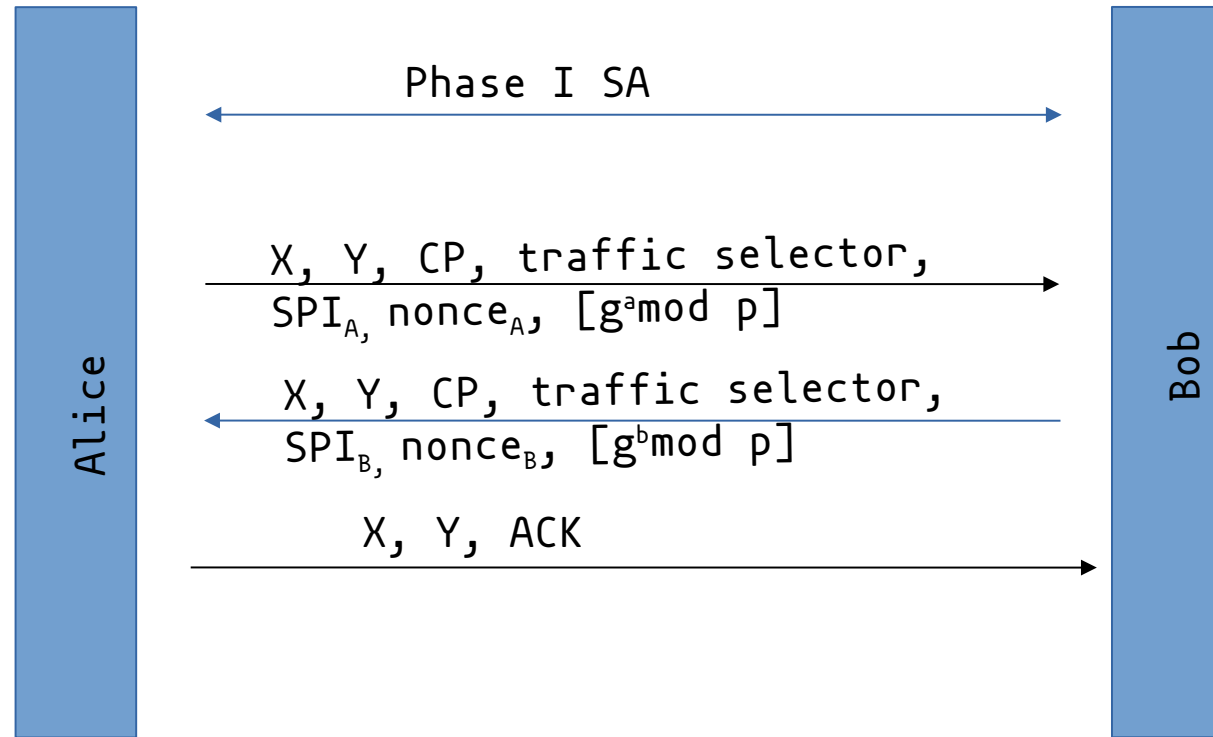
# IKE Phase 1 Protocols - PSK (Aggressive Mode)



# IKE Phase 2

- Used for establishment of IPSec SA for ESP and AH.
- Messages are encrypted with phase 1 keys.
- DH: optionally used for PFS
- Traffic selector (optional): used to select the traffic flow (Src IP, Src Port, Dst IP, Dst Port) to be used with the SA.

# IKE Phase 2



X: Cookie generated in Phase I

Y: 32-bit number to distinguish different (simultaneous) Phase II setups

Other messages:

Authenticator, proposed crypto parameters / accepted proposals, DH exponents (optional), traffic selectors (access control info - IP/Port/Proto allowed etc.) (also optional)



# IKE v2 (vs IKE v1)

No multiple phases (unlike v1). Merely 4 messages establishes the SA (mutual agreement between the communicating parties). Piggybacks sequence numbers and acknowledgements.

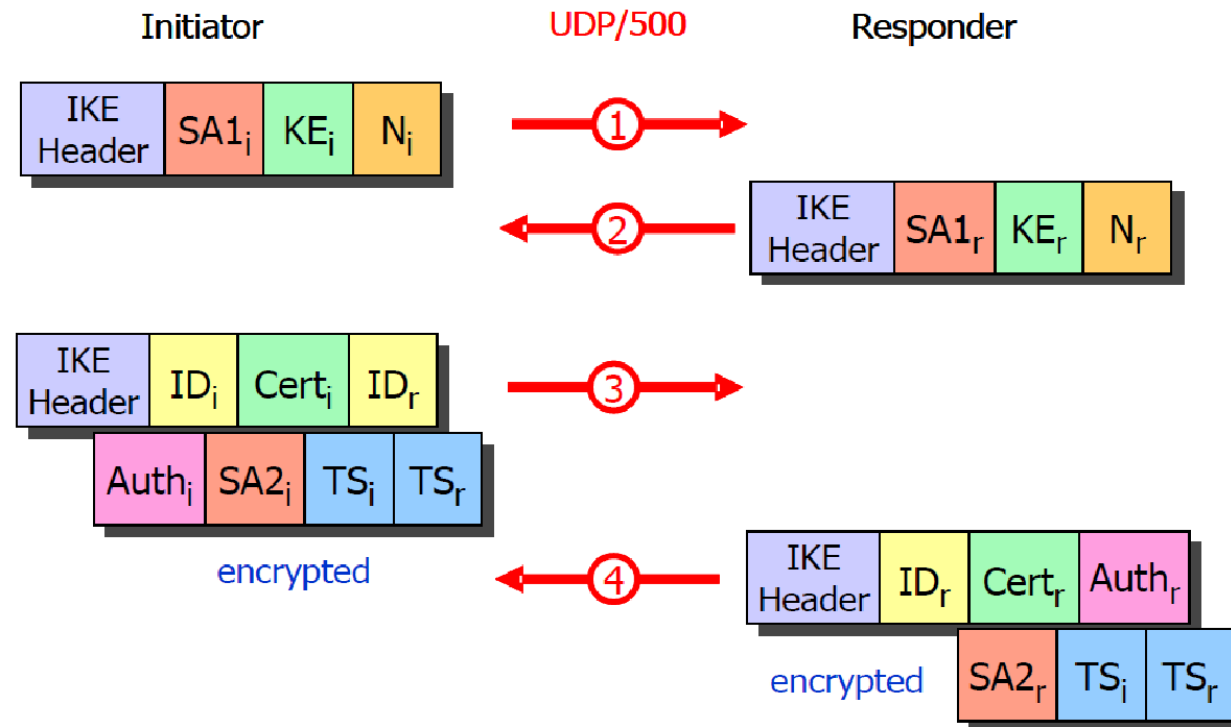


Illustration 4: IKEv2 - IKE\_SA\_INIT and IKE\_AUTH message exchanges

# IKE v2 (important) protocol fields

- $SA_i/SA_r$  : Cryptographic SA proposal and response (acceptance).
- $N_i/N_r$  : Nonces.
- $KE_i/KE_r$ : DH Exponents.
- $AUTH_i/AUTH_r$ : Authentication information derived using PSK or Public-Private Keys.
- $TS_i$

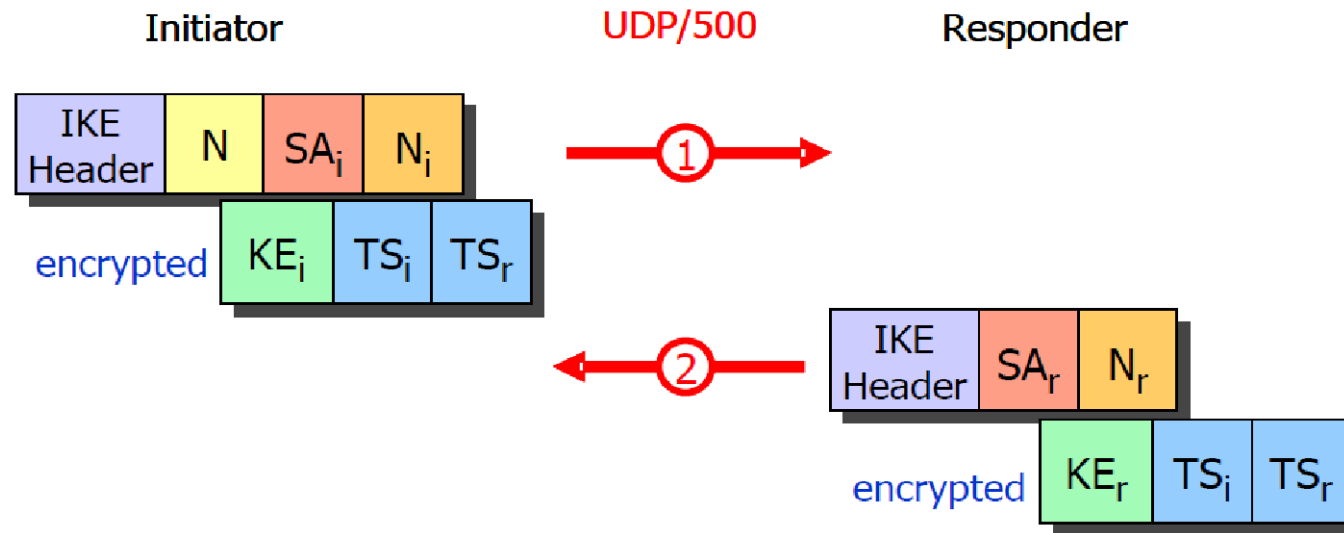


Illustration 5: IKEv2 - CREATE\_CHILD SA message exchange

# Other VPN Protocols - OpenVPN

OpenVPN is an open-source Virtual Private Network (VPN) protocol and software that enables secure point-to-point or site-to-site connections.

- Key Features:
- Uses SSL/TLS for encryption.
- Highly configurable and flexible.
- Open-source, community-driven development.

Purpose: Provides privacy, security, and the ability to bypass geo-restrictions or network restrictions.

Widely used by most commercial VPN providers (e.g. NordVPN, Express, Proton etc.)

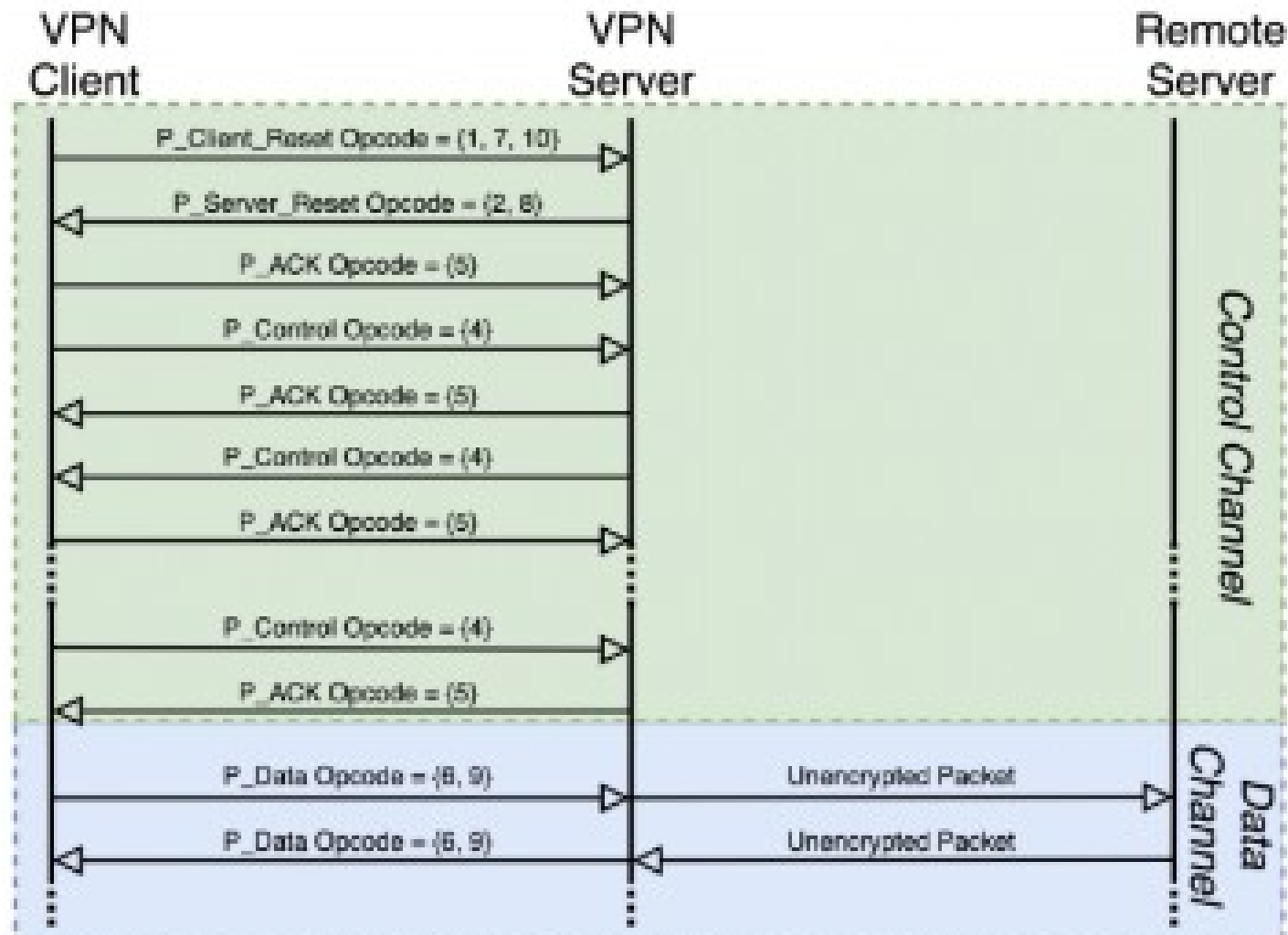
# How OpenVPN Works

OpenVPN is an open-source Virtual Private Network (VPN) protocol and software that enables secure point-to-point or site-to-site connections.

- Key Features:
- Uses SSL/TLS for encryption.
- Highly configurable and flexible.
- Open-source, community-driven development.

Purpose: Provides privacy, security, and the ability to bypass geo-restrictions or network restrictions.

# OpenVPN Handshake - Mimics TLS



- Note: Vanilla OpenVPN handshake is identifiable much like TLS <1.3

# How OpenVPN Works

## Protocol Layers:

- Operates at OSI Layer 2 (Data Link) or Layer 3 (Network).
- Supports TUN (IP routing) and TAP (Ethernet bridging).

## Encryption:

- Uses OpenSSL library for SSL/TLS.
- Supports AES (e.g., AES-256) and other ciphers.

Ports: Typically uses UDP or TCP port 1194 (configurable)

# How OpenVPN Works

## Protocol Layers:

- Operates at OSI Layer 2 (Data Link) or Layer 3 (Network).
- Supports TUN (IP routing) and TAP (Ethernet bridging).

## Encryption:

- Uses OpenSSL library for SSL/TLS.
- Supports AES (e.g., AES-256) and other ciphers.

Ports: Typically uses UDP or TCP port 1194 (configurable)

# Wireguard - Inspired by IPSec

WireGuard is an open-source VPN protocol designed for simplicity, speed, and security.

## Key Features:

- Minimal codebase (~4,000 lines vs. OpenVPN's ~100,000).
- Uses modern cryptography (e.g., Curve25519, ChaCha20).
- Operates at kernel layer, i.e. kernel-integrated VPN tunnel.
- Uses UDP.
- Relies on IKEv2 for handshake.

Purpose: Securely connects devices over untrusted networks with minimal overhead.

Goal: Replace complex VPN protocols with a lean, efficient alternative.



# Wireguard - Core Design Choices

- Performance: Runs in the kernel (on Linux) for speed and efficiency.
- Simplicity: No complex handshake negotiations; uses a single, stateless design.
- Security: Uses state-of-the-art cryptography with no known vulnerabilities.
- Stealth: No persistent connections, making it harder to detect.

# Wireguard - The WireGuard Handshake

## Simplified Process:

- Initiation: Peer A sends an encrypted "Initiator" message with its public key and a timestamp.
- Response: Peer B verifies the message, responds with its own encrypted "Responder" message.
- Key Derivation: Both peers derive a symmetric session key using ECDH.
- Completion: Tunnel is active; data flows with minimal overhead.

## Key Features:

- Takes ~1 round-trip time (RTT).
- Re-handshakes every 2 minutes (default) for fresh keys.
- Key Exchange: Curve25519 (Elliptic Curve Diffie-Hellman) for fast, secure key agreement.
- Encryption: ChaCha20 (stream cipher) for data encryption.
- Authentication: Poly1305 (MAC) for data integrity.
- Hashing: BLAKE2s for internal integrity checks.

# Security Postures

Authentication:

- Pre-shared keys, certificates, or username/password.

Key Exchange: TLS handshake ensures secure key exchange.

Flexibility: Customizable security levels based on needs.